ESEN

# CIBERSEGURIDAD

## Ficha BIA por proceso

Métricas de tiempo, costo de indisponibilidad y valoración

**Ejemplo resuelto de cátedra** · Nexo Crítico Consultores · Energía Nacional S.A. de C.V. (ENSA)

Análisis de Impacto en el Negocio · Plantilla 02 de 07

ISO 22301:2019 · ISO/TS 22317:2021 · NIST SP 800-34 Rev. 1

**Docente:** Ing. Héctor Cuchilla

ESEN – CIBERSEGURIDAD – CICLO 03 – 2026

## Tabla de contenidos

1. Identificación del trabajo..... 3
2. Método de levantamiento empleado..... 3
3. Identificación del proceso analizado..... 4
4. Métricas de tiempo..... 4
5. Nivel mínimo de servicio durante la contingencia (MBCO)..... 5
6. Períodos pico y estacionalidad..... 6
7. Procedimiento alterno y duración máxima sostenible..... 6
8. Costo de indisponibilidad por hora y por día..... 7
9. Valoración económica que el BIA entrega..... 7
10. Método de valoración empleado..... 9
11. Validación..... 9
12. Glosario de los campos de esta plantilla..... 10
Ficha resumida del otro proceso crítico y valoración de los procesos importantes con SLE..... 10

Ejemplo resuelto de cátedra · anexo 2 de 7. La ficha completa corresponde al proceso P-01, Operación de la Red de Control (SCADA/OT); la ficha del otro proceso crítico (P-03) y la valoración de los dos procesos importantes que conservan su SLE (P-04 y P-02) se resumen al final con las mismas variables.

## 1. Identificación del trabajo

Esta plantilla se llena por equipo y sobre la empresa que el equipo tiene asignada en el catálogo del Proyecto Final. El caso resuelto que la Guía del Estudiante desarrolla usa la Red Hospitalaria Metropolitana; cada equipo aplica el mismo método a su propia empresa.

| Campo | Contenido |
|---|---|
| Empresa del catálogo del Proyecto Final | Energía Nacional S.A. de C.V. (ENSA), perfil n.° 4 |
| Sector y tamaño declarados en el perfil | Energía y servicios públicos · mediana, 550 empleados |
| Equipo (número y nombre) | Equipo 04 · Nexo Crítico Consultores |
| Integrantes | Seis integrantes con los cinco roles cubiertos |
| Analista responsable de esta plantilla | Diego Salguero Martínez, analista de riesgos (responsable del rol) |
| Fecha de elaboración | 8 de octubre de 2026 |
| Versión del documento | v1.0 |

## 2. Método de levantamiento empleado

Los datos del análisis de impacto viven en quien opera el proceso, y el analista los extrae con un método declarado. Marcar los medios utilizados y registrar la validación, porque una ficha sin validación del dueño del proceso carece de valor probatorio.

| Medio de levantamiento | Empleado (Sí/No) | Participantes | Fecha |
|---|---|---|---|
| Entrevista estructurada con el dueño del proceso | Sí | Ing. René Alfaro, Gerente de Operaciones de Red; Ing. Carlos Iraheta, Jefe de TI/TO | 7 de octubre de 2026 |
| Cuestionario estandarizado | Sí | Dos operadores del centro de control y un ingeniero de subestaciones | 7 de octubre de 2026 |
| Taller con áreas interdependientes | Sí | Operaciones de Red, Técnica y TI/TO | 8 de octubre de 2026 |
| Revisión documental de registros y contratos | Sí | Contrato de soporte del fabricante SCADA; bitácora de maniobras de los últimos doce meses | 8 de octubre de 2026 |
| Validación firmada por el dueño del proceso | Sí | Ing. René Alfaro | 8 de octubre de 2026 |
| Aprobación de la dirección | Sí | Ing. Óscar Mauricio Handal, Gerente General | 12 de octubre de 2026 |

## 3. Identificación del proceso analizado

Se llena una ficha completa por cada proceso que resulta crítico en la precalificación de BIA_P05 (corte de 24 horas); el proceso importante que trata los datos personales que cuantifica la ficha de datos del cliente llena además las secciones 3, 8 y 9. Toda cifra que no proviene de la ficha de datos del cliente es un supuesto declarado, con su identificador global S-nn, hasta que el dueño del proceso la valida con su firma.

| Campo | Contenido |
|---|---|
| Proceso analizado | Operación de la Red de Control (SCADA/OT) |
| Código del proceso (del inventario) | P-01 |
| Área responsable | Gerencia de Operaciones de Red |
| Dueño del proceso (nombre y cargo) | Ing. René Alfaro, Gerente de Operaciones de Red |
| Servicio que entrega y destinatario | Monitoreo y control en tiempo real de la red de distribución —maniobras, reconexión y supervisión de subestaciones— para los clientes residenciales e industriales y para el operador del sistema |
| Sistemas de soporte | SCADA Siemens (servidores de adquisición, servidores de aplicación y estaciones HMI del centro de control), red de tecnología operacional, enlaces de comunicación con las doce subestaciones principales, radio troncalizado como medio alterno |
| Ventana de operación | 24 × 7 los 365 días, sin ventana de detención programada |

## 4. Métricas de tiempo

El período máximo tolerable de interrupción lo fija el negocio, nunca el área de tecnología, y todas las demás métricas se acomodan por debajo de él. El objetivo de tiempo de recuperación y el objetivo de punto de recuperación se determinan por separado: uno gobierna la capacidad de restauración y el otro la frecuencia del respaldo.

| Métrica | Valor declarado | Unidad | Quién lo declara y con qué fundamento |
|---|---|---|---|
| MTPD / MTD — período máximo tolerable de interrupción | 4 | horas | Gerente de Operaciones de Red: a partir de la cuarta hora sin telecontrol la operación manual no sostiene la reconfiguración de la red ante una falla y la indisponibilidad alcanza a terceros. Deriva del cruce del umbral en BIA_P03 |
| RTO — objetivo de tiempo de recuperación | 2 | horas | Gerente de Operaciones de Red y Jefe de TI/TO: plazo para restablecer los servidores de adquisición y la comunicación con las subestaciones desde el respaldo del sistema SCADA |
| WRT — tiempo de recuperación del trabajo | 1,5 | horas | Operadores del centro de control: verificación de señales, reconciliación de estados de interruptores y retorno del control automático tras la operación manual |

| Métrica | Valor declarado | Unidad | Quién lo declara y con qué fundamento |
|---|---|---|---|
| RPO — objetivo de punto de recuperación | 15 | minutos | Jefe de TI/TO: frecuencia máxima admisible entre respaldos de la base de datos de tiempo real y de la configuración del sistema |
| MBCO — objetivo mínimo de continuidad del negocio | Operación manual de las doce subestaciones principales | descripción | Gerente de Operaciones de Red: supervisión y maniobra local con personal en sitio y comunicación por radio troncalizado, con capacidad para atender fallas aisladas y sin reconfiguración automática de la red |

**Comprobación de coherencia obligatoria:** RTO + WRT ≤ MTPD

RTO declarado: _____ + WRT declarado: _____ = _____ ≤ MTPD declarado: _____

Resultado de la comprobación (Cumple / No cumple): _____

Si la comprobación no se cumple, la ficha no avanza: se corrige el RTO, se corrige el WRT o se justifica ante la dirección un MTPD mayor.

Comprobación obligatoria: RTO + WRT ≤ MTPD → 2 + 1,5 = 3,5 ≤ 4. La ficha cumple con media hora de margen, que el equipo declara deliberadamente estrecha y que sostiene la prioridad del control 11 en el roadmap.

## 5. Nivel mínimo de servicio durante la contingencia (MBCO)

El objetivo mínimo de continuidad declara qué parte del proceso vuelve primero y con qué capacidad, mientras la recuperación completa avanza. Describir la operación reducida en términos verificables: qué se atiende, con qué volumen y con qué personal.

Durante la contingencia, ENSA mantiene la supervisión y la maniobra de las doce subestaciones principales con personal desplazado en sitio y comunicación por radio troncalizado. El nivel mínimo aceptado es: atención de fallas

aisladas con maniobra local, sin reconfiguración automática de la red, sin telecontrol de los equipos de las líneas secundarias y con registro manual de eventos en formulario impreso para su reintroducción posterior. Se requieren doce operadores de campo en turno —uno por subestación—, dos coordinadores en el centro de control y los enlaces de radio operativos. El nivel mínimo no cubre la operación de la red inteligente ni la respuesta a una falla múltiple simultánea: esa es la razón por la que el MTPD es de cuatro horas y no mayor.

## 6. Períodos pico y estacionalidad

El mismo proceso interrumpido produce daños distintos según el momento del año. La planificación de continuidad se dimensiona para el peor escenario temporal, no para el promedio.

| Período pico | Fechas o condiciones | Factor de agravamiento respecto del promedio | Escenario temporal usado en la valoración |
|---|---|---|---|
| Temporada de lluvias y tormentas eléctricas | Mayo a octubre, con concentración en junio y septiembre | 2,2 × en número de fallas simultáneas y 1,6 × en costo por hora | Sí: la valoración usa el escenario de temporada de lluvias |
| Demanda máxima diaria | Días hábiles, 18:00 a 21:00 | 1,4 × en clientes afectados por hora de indisponibilidad | Considerado dentro del escenario anterior |
| Mantenimiento mayor de subestaciones | Enero a marzo, ventanas programadas | 1,3 × por menor redundancia disponible durante la maniobra | No: se documenta y se descarta por ser planificado |
| Cierre de ciclo comercial | Último día hábil del mes | Sin efecto sobre este proceso | No |

## 7. Procedimiento alterno y duración máxima sostenible

La duración máxima sostenible es el dato que suele faltar: cuántas horas o días puede la organización operar en modo alterno antes de que el volumen acumulado desborde al personal, la calidad se degrade o la reconstrucción posterior se vuelva impracticable. Esa duración es la que alarga el MTPD del proceso, y por eso se declara y se verifica.

| Campo | Contenido |
|---|---|
| Descripción del procedimiento alterno | Operación manual: se despliega personal a las doce subestaciones principales, la supervisión se hace con instrumentos locales, las maniobras se ordenan por radio troncalizado desde el centro de control y cada evento se registra en el formulario impreso F-OP-12 |
| Quién lo ejecuta | Operadores de campo de la Gerencia de Operaciones de Red, coordinados por el jefe de turno del centro de control |
| Recursos que exige (personas, formularios, equipos) | Doce operadores por turno más dos coordinadores; radios troncalizados con batería de respaldo; formularios impresos; vehículos de la flota técnica; llaves y permisos de acceso a subestación |
| Duración máxima sostenible | 12 horas continuas, con un solo relevo de turno disponible |
| Cómo se verificó esa duración | Entrevista con el dueño del proceso y revisión de la bitácora del simulacro de operación manual de marzo de 2026, que se sostuvo ocho horas con relevo completo |

| Campo | Contenido |
|---|---|
| Esfuerzo de reconstrucción posterior (alimenta el WRT) | Reintroducción de los eventos registrados en papel, verificación de señales y reconciliación del estado de los interruptores: 1,5 horas de trabajo de dos operadores, que es el WRT declarado |

## 8. Costo de indisponibilidad por hora y por día

Es la métrica más característica del análisis de impacto. Se construye sumando, por cada hora de interrupción, los ingresos que dejan de percibirse, el costo del personal improductivo o en horas extra, las penalizaciones contractuales que se activan y el costo de las medidas alternas. Cuando la dirección pregunta qué se gana con la inversión en continuidad, esta es la cifra que responde.

| Componente del costo | Costo por hora | Costo por día | Supuesto declarado y su origen |
|---|---|---|---|
| Ingresos que dejan de percibirse | USD 38 000 | USD 912 000 | Energía no suministrada durante la indisponibilidad del telecontrol, estimada sobre la demanda media de la zona atendida por las doce subestaciones (derivación de la ficha de datos del cliente: 190 MW de demanda media × USD 200 por MWh, bloque «Economía») |
| Personal improductivo u horas extra | USD 9 500 | USD 228 000 | Doce operadores de campo, dos coordinadores y las cuadrillas de apoyo en horario extraordinario |
| Penalizaciones contractuales activadas | USD 4 500 | USD 108 000 | Compensaciones a clientes industriales con contrato de calidad de suministro (dato de la ficha, bloque «Operación por proceso»: USD 4 500 por hora, entre 2 000 y 9 000) |
| Costo del procedimiento alterno | USD 7 000 | USD 168 000 | Movilización de flota, viáticos, alquiler de equipo de medición portátil y consumo de radio |
| Otros costos directos | USD 3 000 | USD 72 000 | Soporte de emergencia del fabricante del sistema SCADA y horas de consultoría |
| **Total** | **USD 62 000** | **USD 1 488 000** | Escenario de temporada de lluvias; el escenario promedio anual rinde USD 38 750 por hora |

Costo al alcanzar el MTPD de cuatro horas: USD 248 000. Esta cifra es la que sostiene la urgencia de los controles 12 y 13 en E.07 y la que el informe ejecutivo lleva a la dirección.

## 9. Valoración económica que el BIA entrega

El valor del activo es el valor económico total del proceso analizado e incluye el costo de reposición, el valor de la información que contiene y el flujo que genera. El factor de exposición es la proporción de ese valor que se pierde cuando el evento adverso ocurre, expresada entre cero y uno. La pérdida esperada por evento único es el producto de ambos.

| Variable | Valor | Cómo se estimó y con qué fuente |
|---|---|---|
| AV — valor del activo o del proceso | USD 9 000 000 | Valor anual atribuible al proceso de control de red: margen de la energía distribuida por las doce subestaciones principales más el valor de reposición de la plataforma SCADA (derivación de la ficha: USD 6,0 M de margen más USD 3,0 M de reposición, bloque «Economía») |
| EF — factor de exposición (entre 0 y 1) | 0,55 | Proporción del valor del proceso que se pierde en el evento de referencia —cifrado o manipulación del entorno SCADA con indisponibilidad de 24 horas—, estimada con el criterio del dueño del proceso y el costo por día de la sección 8 |
| SLE — pérdida esperada por evento único (SLE = AV × EF) | USD 4 950 000 | 9 000 000 × 0,55. El BIA entrega este valor; la frecuencia (ARO) y la pérdida anual esperada (ALE) se calculan en E.05, tabla D.6 |

**Proceso con los datos personales que cuantifica la ficha.** Cuando el proceso trata los titulares que la ficha de datos del cliente cuenta en el bloque «Economía», se calcula además el SLE de exposición de datos, también si el proceso resulta importante:

| Variable | Valor | Fuente |
|---|---|---|
| Titulares de datos personales que trata el proceso | P-01 no trata datos de clientes; P-04 y P-05 tratan los 420 000 clientes | Ficha de datos del cliente, bloque «Economía» |
| Costo de notificar a un titular (USD) | 0,25 | Ficha de datos del cliente, bloque «Economía» |
| Otros costos por titular que la ficha cuantifica (USD) | Ninguno | Ficha de datos del cliente |
| AV de exposición = titulares × (costo de notificar + otros costos por titular) | USD 105 000 | 420 000 × 0,25 |
| EF = proporción de titulares expuestos en el escenario (entre 0 y 1) | 1,0 | Escenario: exposición de toda la base |
| SLE de exposición = AV × EF | USD 105 000 | SLE-05 (P-04) y SLE-06 (P-05) en E.03, tabla B.2 |

**Escenarios del proceso.** Un mismo proceso admite una pérdida por evento único por escenario (cifrado o indisponibilidad, exposición de datos, fraude, sabotaje de la operación). Cada escenario lleva su identificador SLE-nn, que la tabla B.2 de E.03 consolida y la matriz de riesgos de E.05 cita:

| SLE-nn | Escenario | AV (USD) | EF | SLE = AV × EF (USD) |
|---|---|---|---|---|
| SLE-01 | P-01: cifrado o manipulación del entorno SCADA con indisponibilidad de 24 horas | 9 000 000 | 0,55 | 4 950 000 |
| SLE-02 | P-03: indisponibilidad por cifrado de la plataforma OMS | 2 600 000 | 0,50 | 1 300 000 |
| SLE-03 | P-04: indisponibilidad del sistema comercial | 3 100 000 | 0,45 | 1 395 000 |
| SLE-04 | P-02: indisponibilidad de la cabecera AMI | 1 200 000 | 0,40 | 480 000 |
| SLE-05 | P-04: exposición de los datos personales de los clientes | 105 000 | 1,0 | 105 000 |
| SLE-06 | P-05: exposición de los datos personales de los clientes | 105 000 | 1,0 | 105 000 |

**Frontera del análisis.** Hasta aquí llega el BIA. La tasa anualizada de ocurrencia (ARO) y la pérdida anual esperada (ALE = SLE × ARO) pertenecen a la evaluación cuantitativa de riesgos, tal como la describe NIST SP 800-30 Rev. 1, porque ambas requieren estimar la probabilidad de la amenaza, y la probabilidad queda fuera del alcance del BIA. El BIA responde qué pasa si ocurre; el análisis de riesgos responde con qué frecuencia ocurrirá.

## 10. Método de valoración empleado

| Método | Empleado | Justificación de la elección |
|---|---|---|
| Cuantitativo — valores monetarios | Sí | El proceso tiene costos por hora estimables con la demanda atendida y las compensaciones contractuales; la dirección decide inversiones y necesita cifras comparables con el costo de los controles |
| Cualitativo — escalas verbales alto, medio, bajo | Parcial | Se usa en las categorías reputacional y de seguridad de las personas, donde no hay base monetaria defendible; la matriz de BIA_P03 las califica en la escala 1–5 |
| Semicuantitativo — valores numéricos sobre categorías cualitativas | Sí | La priorización de BIA_P05 convierte las cinco categorías en una escala 1–5 ponderada, lo que permite ordenar procesos con dimensiones no monetarias |

El método semicuantitativo conserva la naturaleza ordinal de su origen: sus números ordenan y ponderan, y no admiten aritmética como si fueran dinero.

El método se declara aquí, en la ficha de cada proceso; BIA_P06 registra solo los supuestos y límites del método, y la sección 3 de BIA_P07 lo resume.

## 11. Validación

| Rol | Nombre y cargo | Fecha | Firma |
|---|---|---|---|
| Analista que levanta la ficha | Diego Salguero Martínez, analista de riesgos | 8 de octubre de 2026 | (firma) |
| Dueño del proceso que valida | Ing. René Alfaro, Gerente de Operaciones de Red | 8 de octubre de 2026 | (firma) |
| Aprobación de la dirección | Ing. Óscar Mauricio Handal, Gerente General | 12 de octubre de 2026 | (firma) |

## 12. Glosario de los campos de esta plantilla

| Término | Definición |
|---|---|
| MTPD / MTD | Período máximo tolerable de interrupción: tiempo tras el cual el daño ya no puede revertirse. Lo fija el negocio. |
| RTO | Objetivo de tiempo de recuperación: plazo máximo para restaurar el proceso y sus sistemas de soporte. |
| WRT | Tiempo de recuperación del trabajo: plazo adicional para reconstruir los datos del período caído y validar su integridad. |
| RPO | Objetivo de punto de recuperación: cantidad máxima de datos que se acepta perder, medida en tiempo. |
| MBCO | Objetivo mínimo de continuidad del negocio: nivel reducido de servicio sostenido durante la contingencia. |
| AV, EF, SLE | Valor del activo, factor de exposición y pérdida esperada por evento único, con SLE = AV × EF. |

## Ficha resumida del otro proceso crítico y valoración de los procesos importantes con SLE

P-03 es el otro proceso crítico: su ficha completa se levantó con el mismo método y la validó su dueño; el detalle de impacto por corte de tiempo vive en BIA_P03 y sus dependencias en BIA_P04. P-04 y P-02 resultaron importantes en BIA_P05 (2,46) y conservan las secciones 3, 8 y 9 de la ficha: P-04 porque trata los datos personales de los 420 000 clientes que cuantifica la ficha (SLE-05), y los dos porque E.05 cuantifica con su SLE los riesgos R-07 y R-04. Sus MTPD, RTO, WRT, RPO y MBCO son los que declara el negocio y los que lista BIA_P05; la regla única de fichas no les exige matriz de BIA_P03 ni mapa de BIA_P04.

| Variable | P-03 · Sistema de Gestión de Interrupciones (OMS), crítico | P-04 · Sistema Comercial y de Facturación, importante | P-02 · Gestión de Medición Inteligente (AMI), importante |
|---|---|---|---|
| Dueño del proceso | Ing. René Alfaro, Gerente de Operaciones de Red | Lic. Marta Rodríguez, Gerente Comercial | Ing. Sonia Portillo, Gerente Técnica |
| MTPD / MTD | 8 horas | 72 horas | 48 horas |
| RTO | 4 horas | 24 horas | 24 horas |
| WRT | 3 horas | 24 horas | 12 horas |
| Comprobación RTO + WRT ≤ MTPD | 4 + 3 = 7 ≤ 8 | 24 + 24 = 48 ≤ 72 | 24 + 12 = 36 ≤ 48 |
| RPO | 1 hora | 4 horas | 6 horas |
| MBCO declarado | Despacho de cuadrillas con planillas impresas y avisos al cliente por el centro de contacto, con corte de reporte cada dos horas | Facturación del ciclo con lectura estimada del período anterior para el 100 % de los clientes regulados, sin gestión de cobro en línea | Lectura manual del 15 % de clientes de mayor consumo y estimación para el resto |

| Variable | P-03 · Sistema de Gestión de Interrupciones (OMS), crítico | P-04 · Sistema Comercial y de Facturación, importante | P-02 · Gestión de Medición Inteligente (AMI), importante |
|---|---|---|---|
| Procedimiento alterno y duración máxima sostenible | Planillas impresas y radio; 24 horas con dos relevos | Estimación de consumo y emisión diferida; 7 días antes de afectar el flujo de caja | Lectura manual programada; 15 días antes de comprometer el ciclo de facturación |
| Costo por hora / por día | USD 18 500 / USD 444 000 | USD 7 400 / USD 177 600 | USD 2 900 / USD 69 600 |
| Costo al alcanzar el MTPD | USD 148 000 | USD 532 800 | USD 139 200 |
| AV · EF · SLE | USD 2 600 000 · 0,50 · USD 1 300 000 | USD 3 100 000 · 0,45 · USD 1 395 000 | USD 1 200 000 · 0,40 · USD 480 000 |
| Período pico usado en la valoración | Temporada de lluvias, factor 2,8 × en volumen de avisos | Cierre de ciclo mensual, factor 1,9 × | Cierre de ciclo diario y facturación mensual, factor 1,5 × |
| Validación | Ing. René Alfaro, 12 de octubre de 2026 | Lic. Marta Rodríguez, 12 de octubre de 2026 | Ing. Sonia Portillo, 12 de octubre de 2026 |